

Security+ 1.1 · Security Controls

Mestre CyberSec — PDF de estudo baseado na aula do Professor Messer · 1.1 — Security Controls (11:48) · Domínio 1 · [vídeo original ↗](#) · [YouTube ↗](#)

Resumo em uma frase: **controles de segurança são qualquer medida que evita, avisa, conserta ou compensa um evento de segurança** — e na prova o que é cobrado é saber classificar cada controle em **uma das 4 categorias** (technical · managerial · operational · physical) cruzada com **um dos 6 tipos** (preventive · deterrent · detective · corrective · compensating · directive).

O mapa mental da aula (a matriz 4 × 6)

O Messer organiza o conteúdo em uma matriz: as **4 categorias** (por QUE ferramenta/processo o controle usa) cruzadas com os **6 tipos de propósito** (o QUE ele faz). Toda pergunta da prova cai em um desses cruzamentos. Memoriza as **linhas da matriz**, não exemplos isolados — o mesmo controle pode mudar de categoria conforme implementado.

Categoria (por meio do que)				
Tipo (propósito)	 Technical	 Managerial	 Operational	 Physical
Preventive — barra antes	Firewall rule, antivírus	Política de onboarding	Guarda conferindo identificação	Fechadura na porta
Deterrent — desanima, não impede	Splash screen de aviso	Ameaça de demissão	Recepção/desk na entrada	Placa de aviso "área restrita"
Detective — identifica depois	System logs, SIEM	Revisar relatório de login	Rondas dos guardas	Detector de movimento
Corrective — repara depois	Restauração de backup	Política de reporte	Chamar a polícia	Extintor de incêndio
Compensating — plano B alternativo	Regra de firewall no lugar do patch	Separation of duties	2+ guardas simultâneos	Gerador de energia
Directive — o "sinal de trânsito"	Diretriz de arquivo sensível	Política de compliance	Treinamento de security	Placa "authorized personnel only"

As 4 CATEGORIAS (por meio do que o controle age)

TECHNICAL

Implementado por uma **ferramenta/sistema técnico** — configuração no sistema operacional, firewall, antivírus, MFA, criptografia. É o que o software/hardware executa sozinho.

Exemplos do Messer: policies no OS, firewall, antivírus

MANAGERIAL

Implementado por **documento + decisão**: política de segurança escrita, procedimento oficial, SOP (standard operating procedure). É o papel que orienta tudo o resto.

Exemplos: security policy document, SOP, risco

OPERATIONAL

Implementado por **pessoas no seu dia-a-dia**: guardas, treinamento, awareness (posters, lunch-and-learns), resposta a incidente por humanos.

Exemplos: guardas, lunch-and-learns, posters, awareness

PHYSICAL

Limita acesso **físico** a prédio/sala/equipamento: fechadura, cercas, badge reader, guard shack, bollard, câmera, mantrap.

Exemplos: guard shack, cercas/fechaduras, badges

Os 6 TIPOS (pelo propósito do controle)

1) PREVENTIVE — barra antes de acontecer

Impede o acesso/ação. É o tipo mais cobrado. Firewall rule que bloqueia IP, antivírus, MFA, fechadura na porta, guarda conferindo crachá, política de onboarding.

DETERRENT — desanima, mas não impede

Serve para o atacante **pensar duas vezes**: splash screen de sistema (technical), ameaça de demissão (managerial), recepção na entrada (operational), placa "área monitorada" (physical). Diferença pra preventive: o deterrence DEPENDE de o ataque acontecer ou não decidir-se; o preventive não dá a chance.

DETECTIVE — avisa / registra depois

Acha o evento quando já aconteceu: system logs, login reports revisados, patrulha, detector de movimento. Não barra nada — **avisa**.

CORRECTIVE — repara depois do evento

Ação que repara/limita impacto depois que o evento aconteceu: restore de backup (ransomware), patch posterior, chamar a polícia, extintor de incêndio.

COMPENSATING — alternativo quando o impossível

Quando **não dá** pra implementar o controle ideal, compensa de outra forma **temporária ou complementar**: firewall rule no lugar do patch (sistema legado), separation of duties, 2 guardas simultâneos, gerador. Messer chama de "using OTHER means".

DIRECTIVE — direciona, mas não obriga tecnicamente

O tipo MAIS FRACO: só DIREciona o comportamento (o usuário decide se cumpre): file storage policy, compliance guidelines, security training, placa "authorized personnel only". Dependem de boa-fé — sem técnico que barra.

🗨️ Como o Messer ensina a raciocinar (a dica mais importante da aula)

Duas perguntas, nessa ordem:

1. **"O QUE esse controle faz?"** — é preventivo (barra antes), deterrente (desanima), detective (avisa depois), corrective (repara), compensating (plano B) ou directive (direciona)?
2. **"COMO ele é implementado?"** — por ferramenta (technical), por documento (managerial), por pessoas (operational) ou por barreira física (physical)?

Então cruze a resposta: **firewall rule = preventive + technical**. O Messer ensina exatamente essa combinação — e a prova cobra exatamente esse raciocínio com exemplos novos que você nunca viu.

💡 Highlights que a prova cobra (o que o Messer enfatizou)

📌 Categorias vs Tipos

- **Categorias (4):** TECHNICAL · MANAGERIAL · OPERATIONAL · PHYSICAL — respondem "COMO é implementado"
- **Tipos (6):** Preventive · Deterrent · Detective · Corrective · Compensating · Directive — respondem "O QUE ele faz (quando no tempo)"
- A prova quase SEMPRE te dá um exemplo e pede pra classificar nas duas dimensões — não só em uma

📌 Pegadinhas clássicas

- **Firewall:** pode ser preventive (regra bloqueia) OU detective (log) — olha o CONTEXTO da pergunta
- **Antivírus:** technical + preventive (bloqueia) E detective (alerta) — ambos dependem da configuração
- **Ferramenta física como extintor:** corrective (repara o fogo), NÃO preventive
- **Treinamento:** directive (direciona) + operational (pessoas) — não é preventive
- **Guarda conferindo crachá** na entrada = preventive + operational

Dicas específicas para a prova (o "Messer tip" desta aula)

Como a prova cobra esta aula

A prova **NÃO** pergunta "qual categoria tem firewall?" — ela te dá um **EXEMPLO COMPLETO** e pede a classificação. Exemplos típicos de pergunta:

- *"Uma organização exige que dois administradores autorizem acessos críticos pra evitar que um sozinho cause dano."* → **Compensating + managerial (separation of duties)**
- *"Após identificada uma tentativa de acesso indevido, o sistema reverte o ambiente ao último backup válido."* → **Corrective + technical**
- *"Placa na porta: 'acesso autorizado apenas' — sem fechadura."* → **Directive + physical**

Termo gatilho: "after the event" = corrective · "discourage but not prevent" = deterrent · "identifies/logs" = detective · "alternative approach" = compensating

Perguntas de treino (10 questões — mesmas da prova real)

Gabarito no fim. Tenta responder SEM olhar. Se errar 3+ desta lista, revê o vídeo e a matriz antes de seguir pro próximo.

1. Um administrador instala uma regra de firewall que bloqueia todo tráfego de entrada vindo de uma faixa de IP conhecida por ser maliciosa. Qual combinação classifica corretamente este controle?

- B) Preventive · Technical
- C) Detective · Technical
- D) Preventive · Managerial
- A) Deterrent · Technical

2. A empresa instala placas na entrada dizendo "esta área está sendo gravada por câmeras de segurança". Nenhum dispositivo físico novo foi adicionado. Qual é o propósito deste controle?

- B) Preventive
- C) Detective
- D) Deterrent
- A) Compensating

3. Depois de um ataque de ransomware, o time de TI apaga o disco da máquina e restaura os dados do backup de ontem. Este controle é:

- B) Detective**
- C) Corrective**
- D) Preventive**
- A) Compensating**

4. Um software crítico da empresa tem uma vulnerabilidade grave, mas o fornecedor só poderá enviar o patch em 2 meses. A solução temporária de bloquear a porta específica no firewall até o patch chegar é qual tipo de controle?

- B) Corrective**
- C) Detective**
- D) Compensating**
- A) Preventive**

5. A organização implementa a política de que NINGUÉM (nem o administrador do sistema) pode aprovar e executar um pagamento sozinho — sempre precisa de duas pessoas. Isso é:

- B) Preventive control do tipo managerial (separation of duties)**
- C) Detective control do tipo technical**
- D) Compensating control do tipo operational (dupla guarda)**
- A) Directive control do tipo physical**

6. Guardas fazem rondas pelo prédio a cada hora. Quando um guarda descobre portas abertas que não deviam estar, reporta. Este controle é:

- B) Detective · Operational (patrulha)**
- C) Preventive · Physical (patrulha)**
- D) Corrective · Operational**
- A) Detective · Technical**

7. A empresa escreve um documento oficial de política de segurança que define como funcionários devem tratar dados sensíveis. Qual o tipo + categoria?

- B) Directive + Managerial
- C) Preventive + Managerial
- D) Directive + Technical
- A) Corrective + Managerial

8. Depois de um ataque bem-sucedido, o time de segurança monta um relatório do que aconteceu pra evitar repetição — inclusive atualizando o playbook. Qual controle é este?

- B) Detective
- C) Corrective — na categoria managerial (processo, documentação)
- D) Preventive
- A) Compensating

9. O datacenter instalou **detector de movimento que dispara alarme e notifica os guardas quando há movimento fora do horário. Esta combinação:**

- B) Detective + Technical
- C) Detective + Physical
- D) Preventive + Physical
- A) Deterrent + Technical

10. Depois de um incidente, o time de segurança adiciona um **módulo de antivírus adicional à borda da rede, porque o sistema legado não pode ter o patch aplicado. Este é um exemplo de:**

- B) Compensating control — uma alternativa porque o controle ideal (patch) não é possível
- C) Corrective control — corrige o que já aconteceu
- D) Preventive — barra o ataque antes
- A) Deterrent — desanima o atacante

GABARITO COMENTADO

- 1) A — Preventive · Technical.** Firewall é ferramenta (technical); a regra BARRA ANTES do ataque (preventive).
- 2) C — Deterrent.** O aviso desanima, mas não impede tecnicamente — a câmera que registra é detective; a placa que AVISA é deterrent.
- 3) B — Corrective.** Aconteceu DEPOIS do evento: restaurou e corrigiu. Não preveniu nem detectou.
- 4) C — Compensating.** O controle ideal seria o patch; como não é possível HOJE, usa-se uma alternativa TEMPORÁRIA (firewall block). Definição exata de compensating.
- 5) A — Preventive · Managerial (separation of duties).** É política (managerial) que BARRA o erro do primeiro processo (preventive). Messer cita separation of duties como compensating, mas em geral também é preventive.
- 6) A — Detective · Operational.** Patrulha é o dia-a-dia de guardas (operational), e ela DETECTA (acha problema), não previne.
- 7) B — Preventive + Managerial.** Política (managerial) que ORIENTA e EVITA o erro (preventive).
- 8) B — Corrective + Managerial.** Depois do evento, documenta e melhora (corrective) via processo/documento (managerial).
- 9) B — Detective + Physical.** Detector de movimento é dispositivo FÍSICO e DETECTA (não previne) — dispara alarme.
- 10) A — Compensating.** O controle IDEAL (patch) não é possível; usa-se alternativa. Messer chamou exatamente de "using other means".

Links desta aula

[Página oficial da aula ↗](#) · [Vídeo no YouTube ↗](#) · [Course Notes \(PDF pago do Messer\) ↗](#)
· [Objectives oficiais \(PDF CompTIA\) ↗](#)